

Recap

Security threats affecting email services are mainly due to the lack of built-in security mechanisms

To ensure privacy, confidentiality and integrity of mail objects, SMTP supports TLS

No guarantee of end-to-end protection from the sender MUA to the recipient MTA (TLS is negotiated at the level of a single hop)

Specific authentication and validation technologies are implemented to fight spoofing

Reverse lookup checks the IP address of the sender

SPF checks the compliance of the message with sender's policies

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

34

Header fields

Specific header fields (often customized by domain administrators) are used to define the outcome of the SPF check

These headers are inserted in the header section of the mail object by the recipient MTA

```
Received-SPF: pass (google.com: domain of [REDACTED]
designates 209.85.220.41 as permitted sender) client-ip=209.85.220.41;
```

```
Received-SPF: softfail (google.com: domain of transitioning
accounts@almuradsign.com does not designate 95.79.27.192 as permitted
sender) client-ip=95.79.27.192;
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

35

Domain Keys Identified Mail

DKIM is an open standard that belongs to the class of **content authentication** protocols used to validate the authenticity of a message [[RFC 5585 “DomainKeys Identified Mail \(DKIM\) Service Overview”](#) published in 2009]

It is a joint effort that combines and enhances two products originally developed by Yahoo! and Cisco, i.e., Domain Keys and Internet Identified Mail

The idea is to digitally sign a message such that the sender Mail Server takes the responsibility of the message in transit and the recipient Mail Server can verify its authenticity and integrity (e.g., message not modified in transit)

DKIM requires the cooperation of sender and recipient Mail Servers

DKIM is generally used to build the *reputation* of a brand/domain (e.g., good delivery practices, low spam rate)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

36

DKIM implementation

DKIM implementation is based on a digital signature computed using public/private key (asymmetric) cryptography

The DKIM signature applies to message body and selected header fields

Sender Mail Server computes a hash of the selected header fields and another hash of the body and uses the private key to cryptographically encode this information before transferring the mail object

Recipient Mail Server receives the message and checks the signature using the public key associated with the sender domain

The public key is stored in the DNS as a Resource Record of type **TXT** (DNS is the “trusted entity”)

Each organization can use multiple public/private key pairs (differentiated by a *selector* or *key reference*)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

37

Header field

DKIM-Signature is a specific header field used to implement DKIM

This header is inserted in the message by the sender Mail Server and contains all information (e.g., algorithm, domain name and selector, signature) required for the message validation

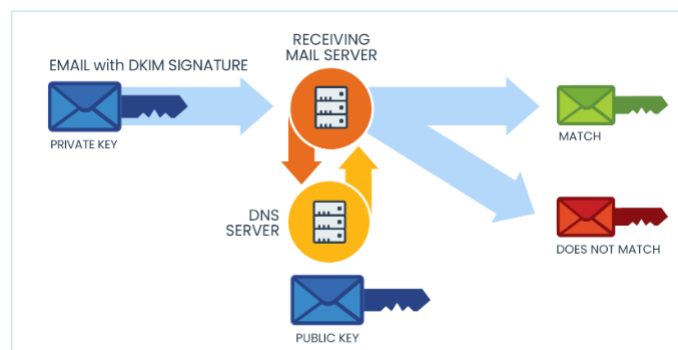
```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=unipv-  
it.20251104.gappssmtp.com; s=20251104; t=1779810281; x=1780415081;  
h=content-transfer-encoding:subject:from:to:content-language :user-agent:mime-  
version:date:message-id:from:to:cc:subject:date :message-id:reply-to;  
bh=Q2PzHC3SpotSdecu/q+JqThg3e2rXj4CTp855UjMFB0=;  
b=uwJDZUNUPHX9RWTN1ngMIx0mn2yGNgluBkpgefYQ82BayYj5h5AH915/TNo10Qs359  
cwV6j+1B6t2ed02zBTD2Wvok12JZ0he7bdjhak4xCwcKYyzLfn/z9ZDJ69SxcxFVoHqv  
YrXS2BwRWhthsMH0QmM9iIiZ8+xbwPxvySDQ0QGj0VHYZ0rv/DtiA+NhD2T2Bfow0EzG  
QvQfms8Ns56AgtFTVMC12e0XueEKgMY6DepZr6iHhQNiW70miTmQ7AxMg4K5C9Kyhb/0  
p1ULavMPWFX6EvPz3i1uycz0l891dYt70ymi32/LO26GSfFeeRNRBP14dUWaU0FFn1xF vJKw==
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

38

DKIM



Query: `selector._domainkey.domain-name IN TXT`

`20251104._domainkey.unipv-it.20251104.gappssmtp.com IN TXT`

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=unipv-  
it.20251104.gappssmtp.com; s=20251104; t=1779810281; x=1780415081;
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

39

DNS query for DKIM

```
mac@kali:~$ dig -t TXT 20251104._domainkey.unipv-it.20251104.gappssmtp.com

;<<>> DiG 9.18.48 <<>> -t TXT 20251104._domainkey.unipv-it.20251104.gappssmtp.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 59285
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;20251104._domainkey.unipv-it.20251104.gappssmtp.com. IN      TXT

;; ANSWER SECTION:
20251104._domainkey.unipv-it.20251104.gappssmtp.com. 3600 IN TXT "v=DKIM1; k=rsa; p=MI
IBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA07CELMkYFkCPJquA07AWm5I9mdQxdX29e+pjtZGARQ5C
UcI2HJFEVYy6b9nYkC8q+ODdRRNWLLYIjF+1VYB1BQLw1GbNcm6W0R9RAxqmVOq7mcXmP2IktbigyfSUzc80W0S
JUAnSmaIY9mEzvZVJ+siEVNVOfTPMUanwfhwZyVJqTqKRcmSwIrjj6I1HqfI1QM" "0hkXHHfFaXc2AizlIaHq
JZQycytpo1/mH9ppZThVmdXxcEI+nf7X2m13QN386fB6CTCnI3rm/Q8Kie0fhhfIfnl/7IPjmaHI/isDersXJw
ktMksLG6To1cRceo0Ij1W64dn1ghAS1cTn0zM2zB+kwIDAQAB"

;; Query time: 140 msec
;; SERVER: 127.0.0.53#53(127.0.0.53) (UDP)
;; WHEN: Tue May 26 21:33:32 CEST 2026
;; MSG SIZE rcvd: 504
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

40

DKIM implementation

On the sender Mail Server:

- Registration of dedicated sub-domain(s)
- DNS admin tools for creating (updating) RRs to store the public key
- Selection of the header fields to be encrypted
- Software for encrypting/encoding the selected headers and the body

On the recipient Mail Server:

- Resolver to query DNS
- Software for verification/validation of the encrypted mail content

Outcome:

- Pass or Fail

DKIM does not ensure privacy/confidentiality of the messages

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

41

DMARC

Domain-based Message Authentication, Reporting and Conformance (DMARC) is another message authentication policy that tries to overcome spoofing vulnerabilities affecting SPF and DKIM

SPF only inspects the envelope (i.e., **MAIL FROM**) but does not consider the address displayed to the users (i.e., **From** field in the header)

Attackers could use a domain under their control for the **MAIL FROM**, thus passing the SPF check and use a spoofed email address in the **From** to fool users

For DKIM attackers could sign the message using a key associated with their own domain and use a spoofed email address in the **From** to fool users

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

42

DMARC (cont'd)

Sender domain owners do not receive any feedback on the effectiveness of their message authentication deployments

Sender and receiver domain owners do not share information between each other

Receivers do not supply senders with information about their authentication infrastructure

Senders do not specify what to do in case a message does not authenticate

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

43

DMARC features

DMARC is a standard message authentication and reporting policy [[RFC 9989 Internet Draft “Domain-based Message Authentication, Reporting, and Conformance \(DMARC\)”](#) published in May 2026] (*in 2015 RFC 7489 independent submission by Yahoo! Now obsolete*)

Approach pioneered by PayPal in 2007 with YahooMail and later by Google

Domain owner expresses domain-level policies and preferences for message validation, disposition and reporting that pretend to be sent from its domain

Recipient Mail Servers use this information to improve their mail handling

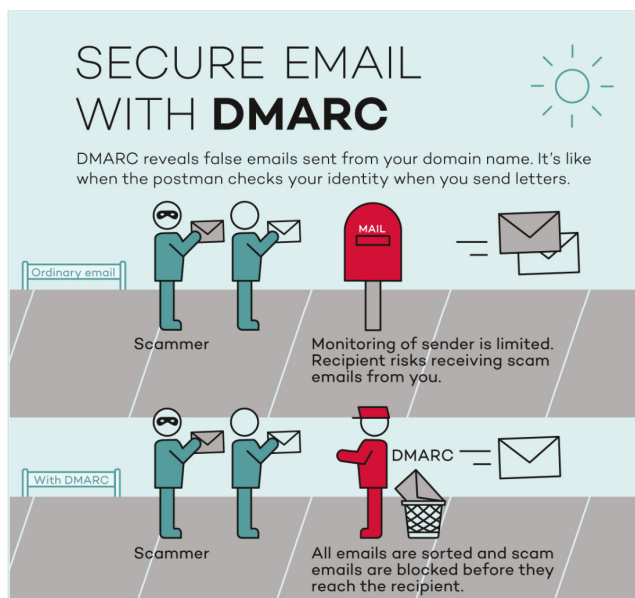
The main objective of DMARC is to reduce the number of malicious messages that pretend to be sent by a well-known company

DMARC allows *protecting brands and reputation* from fake messages

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

44



© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

45

DMARC added value

DMARC complements SPF and DKIM by adding new distinctive features

1. It checks the alignment of the various domain identities specified inside a mail message
2. It provides a means for the sender domain owner to specify a policy on how receivers must handle failing messages
3. It reports failing messages to sender domain owners and makes it easier to identify phishing campaigns or errors in authentication/validation policy implementation

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

46

Identifier alignment

The alignment is a key concept of DMARC applied to authenticate messages

DMARC considers all identities (i.e., domain names) specified in a mail object and checks their alignment

It considers the identities used by SPF and DKIM technologies (i.e., **MAIL FROM**, DKIM signing domain) and the identity specified in the **From** header (displayed to the users)

An alignment in all identifies specified in the message will result in a DMARC *pass*

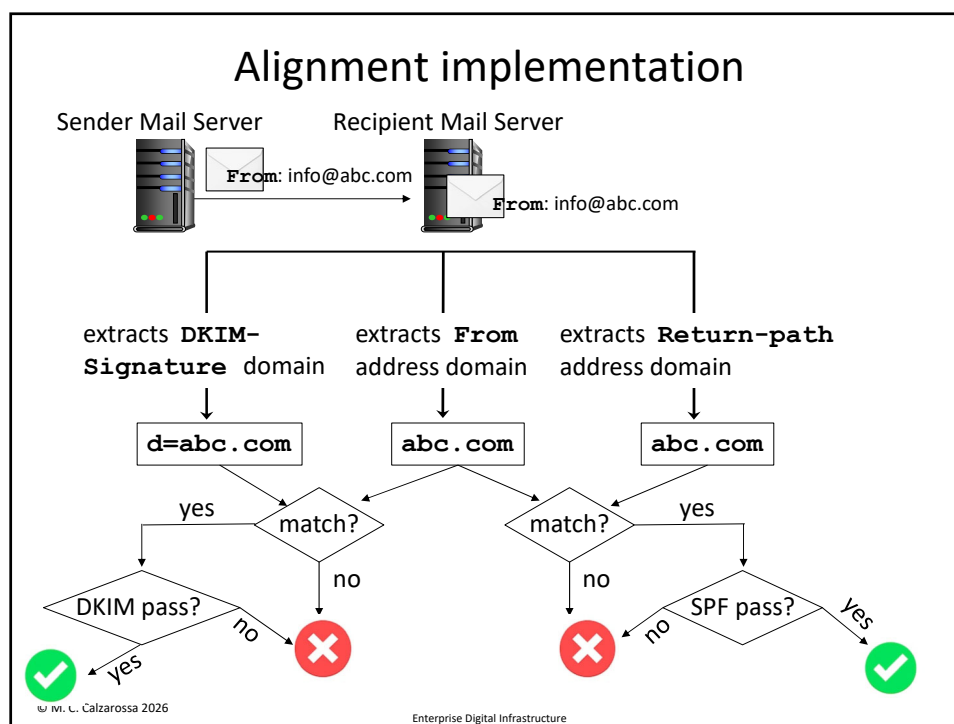
A mismatch in any of the identifies specified in the message will result in a DMARC *fail*

The outcomes of the validations performed by SPF and DKIM are also considered

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

47



48

DMARC policy

Domain owners define their DMARC policies by specifying:

1. How receivers verify the authenticity of the messages
2. How receivers handle messages that fails to verify
3. How often/which reports receivers send to domain owners

DMARC uses a simple DNS-based policy distribution mechanism based on a **TXT** Resource Record with a dedicated domain name (i.e., **_dmarc.domain-name**)

Recipient Mail Server queries the DNS to obtain the Resource Record associated with DMARC

The disposition policy encoded in the RR can be set to:

- *none*, i.e., failed messages to be reported only
- *reject*, i.e., failed messages to be rejected (in mail transaction phase)
- *quarantine*, i.e., failed messages to be considered suspicious

Policy setting is *critical* to avoid false positives

© M. C. Calzarossa 2026 Enterprise Digital Infrastructure

49

DMARC reporting

Reporting is a distinctive feature of DMARC

Domain owners get feedback on the implemented policies (e.g., SPF, DKIM, identifier alignment, message disposition) and can make them more effective

Two types of reports:

1. Aggregated reports periodically generated for all messages received from a given domain
2. Failure reports generated on a message by message basis for messages failing DMARC checks

Benefits for domain owners:

1. Possibility to build a detailed picture of the messages being sent and how they appear to recipients
2. Possibility to debug and tune SPF and DKIM policies and know whether their domain is being abused for phishing/spam campaigns

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

50

Format of the **TXT** Resource Record

```
"v=DMARC1; adkim=r; aspf=s; p=none; pct=100; rf=afrr; ri=86400;
ruf=mailto:forensics.example.com;"
```

adkim and **aspf** are used to set the alignment mode for DKIM and SPF

Strict: the Fully Qualified Domain Name in the record must be an exact match for the **From** domain

Relaxed: the organizational domain in the record must match that of the **From** domain

p: policy (i.e., none, reject, quarantine)

pct: percentage of messages subjected to filtering

rf: format of individual forensic reports (e.g., authentication failure reporting format)

ri: reporting interval

ruf: reporting URI for forensic reports

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

51

Examples of RRs

version

```

_dmarc.universitadipavia.it. 3600 IN      TXT      "v=DMARC1;
p=none; rua=mailto:dmarc-notification@unipv.it"

```

policy

reporting URI for aggregated reports

```

_dmarc.paypal.com. 3600 IN      TXT      "v=DMARC1;
p=reject; rua=mailto:d@rua.agari.com; ruf=mailto:d@ruf.agari.com"

```

failure reporting option

reporting URI for failure reports

```

_dmarc.bancaintesa.it. 14800 IN      TXT      "v=DMARC1;
p=reject; fo=1; ri=3600; rua=mailto:intesa-sanpaolo@rua.dmp.cisco.com; ruf=mailto:intesa-sanpaolo@ruf.dmp.cisco.com"

```

```

_dmarc.bbc.com. 3600 IN      TXT      "v=DMARC1;
p=quarantine; sp=reject; aspf=s; adkim=s; pct=100; fo=0; ri=86400;
rua=mailto:02fd5b325c28457@rep.dmarcanalyzer.com; ruf=mailto:02fd5b325c28457@for.dmarcanalyzer.com;"

```

© M. C. Calzarossa 2026
Enterprise Digital Infrastructure

52

Authentication outcome

```

Authentication-Results: mx.google.com;
      dkim=pass header.i=@universitadipavia-it.20230601.gappssmtp.com
      header.s=20230601 header.b=dt6DF1K0;
      spf=pass (google.com: domain of
      [REDACTED]@universitadipavia.it designates 209.85.220.41
      as permitted sender)
      smtp.mailfrom=[REDACTED]@universitadipavia.it;
      dmarc=pass (p=NONE sp=NONE dis=NONE)
      header.from=universitadipavia.it;

```

© M. C. Calzarossa 2026
Enterprise Digital Infrastructure

53